Team "don't hack me im sensitive"

Iowa State University

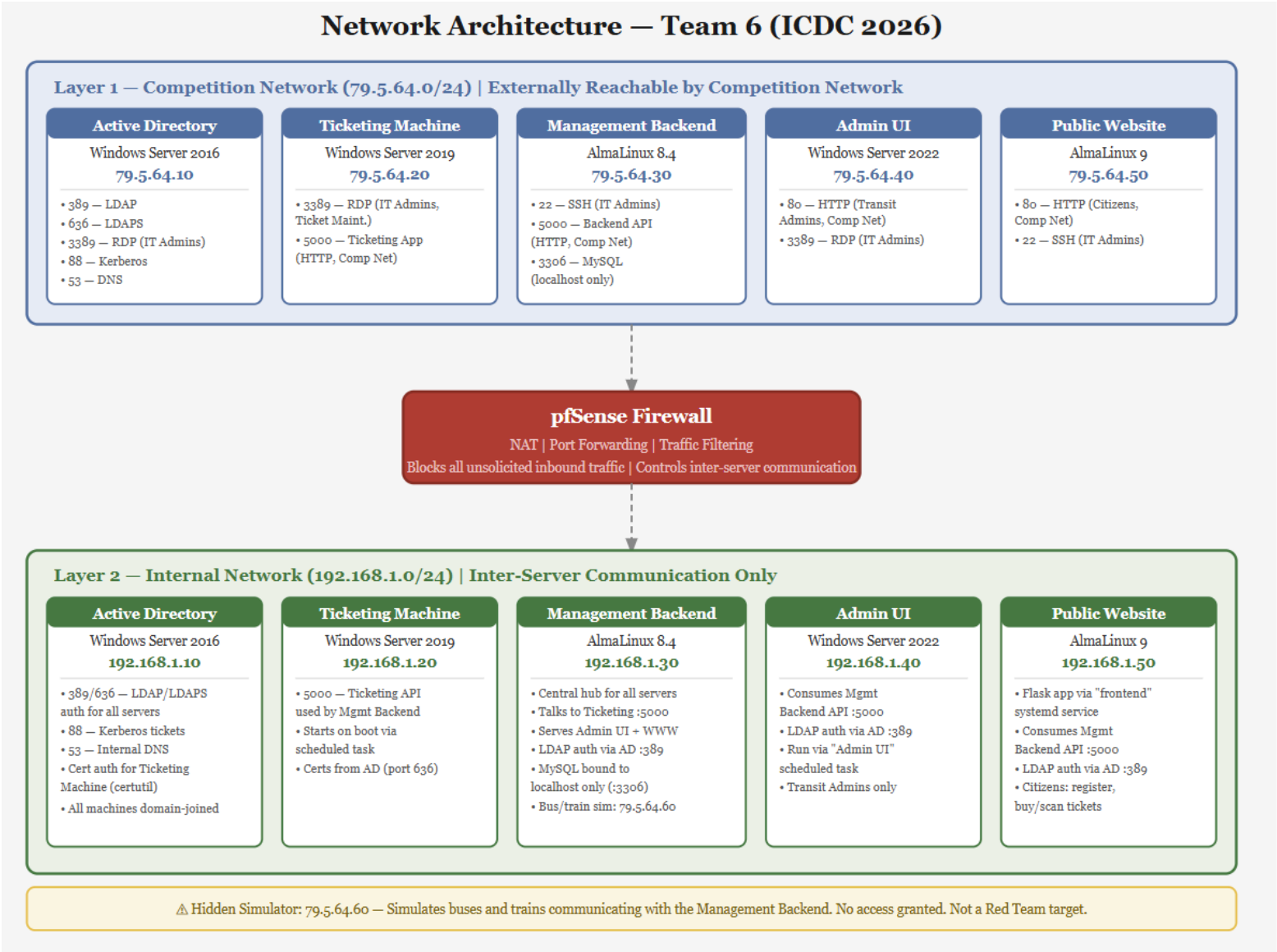
white team documentation

(Team 6)

Table of Contents

Table of Contents 2
Network Architecture 3
Active Directory 4
Ticketing Machine 5
Management Backend 6
Admin UI 7
WWW Public Website 8
User Roles and Access Controls 10
Known Risk and Monitoring 11

Network Architecture



Our network is built across two layers. All five servers sit on the competition-facing subnet (79.5.64.0/24) where required services are publicly accessible, and simultaneously on an internal subnet (192.168.1.0/24) behind a pfSense firewall where all inter-server communication takes place. pfSense acts as the single entry point, handling NAT, port forwarding, and traffic filtering between the two layers. Internally, the Management Backend (192.168.1.30) serves as the central hub — the Public Website, Admin UI, and Ticketing Machine all communicate through it. Active Directory (192.168.1.10) provides centralized LDAP authentication and certificate services for all servers on the network. A hidden machine at 79.5.64.60 simulates bus and train communication with the Management Backend and is not accessible to or targeted by the Red Team.

Active Directory

Server: ad.team6.isucdc.com
IP (external): 79.5.64.10
IP (internal): 192.168.1.10
Operating System: Windows Server 2016

The Active Directory server is the authentication backbone of the entire network. All five machines are domain-joined to this server, which provides LDAP/LDAPS authentication, Kerberos ticketing, DNS, and certificate services for the Ticketing Machine.

SMB Hardening SMBv1 was disabled to eliminate the EternalBlue attack surface. SMB signing was set to required and SMB encryption was enabled. All share permissions on NETLOGON, SYSVOL, and CertEnroll were verified to be correct with no excessive access.

LDAP Hardening LDAP signing was enforced by setting LDAPServerIntegrity to 2 (Require). LDAP channel binding was enabled and set to Always (LdapEnforceChannelBinding = 2). Anonymous LDAP enumeration was restricted by setting RestrictAnonymous to 1. LDAPS is available on port 636.

Protocol Attack Mitigations Print Spooler was stopped and disabled to prevent PrintNightmare exploitation. LLMNR was disabled via registry to prevent credential capture attacks. NetBIOS over TCP/IP was disabled on all network adapters to prevent NTLM relay attacks.

RDP Access Control RDP access is restricted to IT Administrators only and locked to the competition subnet (79.5.64.0/24). Network Level Authentication is enforced.

Certificate Services The misconfigured enrollment agent template was removed to eliminate the ADCS ESC vulnerability. Certificate enrollment for the Ticketing Machine was verified using certutil.

Ticketing Machine

Server: tickets.team6.isucdc.com
IP (external): 79.5.64.20
IP (internal): 192.168.1.20
Operating System: Windows Server 2019

The Ticketing Machine hosts the city's ticket issuing and validation system for buses and trains. It runs a C# ASP.NET Core application located at C:\Users\Administrator\Desktop\tickets, which starts automatically on boot via a scheduled task.

Application Security The `/api/tickets/help` endpoint was removed entirely, as it was exposing the full RSA private key as a base64-encoded PKCS12 certificate to any unauthenticated caller. This would have allowed Red Team to forge tickets locally without touching the signing endpoint. Server-side expiration validation was added to reject any ticket signing request where `validUntil` is greater than or equal to 2000000000, blocking the forged ticket flag condition. The same check was added in the TicketSigner service as a second layer of defense.

Network Hardening RDP access on port 3389 is restricted to IT Administrators and Ticket Maintenance groups only, locked to the competition subnet. Network Level Authentication is enforced. Port 5000 is restricted so only the Management Backend and competition network can reach the ticketing application.

SMB Hardening SMBv1 was disabled. SMB signing was set to required and access was restricted to the internal subnet only.

Management Backend

Server: mgmt.team6.isucdc.com
IP (external): 79.5.64.30
IP (internal): 192.168.1.30
Operating System: AlmaLinux 8.4

The Management Backend is the central hub of the entire infrastructure. It handles user authentication, ticket payments, and fleet and route management for all city transportation. The Admin UI, Public Website, Ticketing Machine, and hidden bus/train simulator all communicate through it. The application runs as a systemd service called "backend" located at /home/cdc/icdc26-backend-mgmt.

Default Account Hardening The default cdc user password was changed to the TSI value provided via IScorE. The cdc@% MySQL user, which permitted database connections from any remote host, was removed entirely. Anonymous MySQL users and the default test database were also dropped. The MySQL root account is restricted to localhost only.

Database Security MySQL/MariaDB was bound to localhost only (127.0.0.1), preventing any external database connections. All other inbound traffic to port 3306 is blocked at the firewall level.

Application Security The hardcoded weak SECRET_KEY of "cdc" was replaced with a cryptographically secure randomly generated value. Hardcoded LDAP Administrator credentials in the application config were identified and secured. Inter-server hostname resolution was fixed by adding static /etc/hosts entries mapping IP (internal)s to hostnames, ensuring reliable LDAP authentication back to Active Directory.

Unnecessary Services Disabled rpcbind (port 111), Performance Co-Pilot monitoring services (pmcd, pmlogger, pmie), and the Cockpit web administration interface were all stopped and disabled, reducing the attack surface significantly.

Firewall Configuration firewalld was configured to allow only three services: SSH on port 22, the backend API on port 5000, and MySQL on localhost only. All other inbound traffic is blocked.

SSH Hardening SSH was hardened to prevent tunneling and lateral movement by disabling port forwarding, stream forwarding, and agent forwarding, all common Red Team pivoting techniques.

Admin UI

Server: admin.team6.isucdc.com
IP (external): 79.5.64.40
IP (internal): 192.168.1.40
Operating System: Windows Server 2022

The Admin UI hosts the city's transit management portal, used by Transit Admins to view the status of the transportation system and manage the vehicle fleet. The application is located at C:\Users\Administrator\Desktop\icdc26-admin-ui and runs automatically via a scheduled task called "Admin UI." It communicates exclusively with the Management Backend on port 5000.

Access Control RDP access on port 3389 is restricted to IT Administrators only and locked to the competition subnet. Network Level Authentication is enforced. Transit Admins (edward.matthews, joy.newman) are granted access to the web interface on port 80 but do not have RDP privileges. Unnecessary local accounts were reviewed and removed.

Windows Hardening The same baseline hardening applied across all Windows machines was implemented here. SMBv1 was disabled and the system upgraded to SMBv2 with signing required. Print Spooler was stopped and disabled to prevent PrintNightmare exploitation. LLMNR was disabled via registry to prevent credential capture attacks. NetBIOS over TCP/IP was disabled on all network adapters to prevent NTLM relay attacks.

Network Hardening Windows Firewall rules restrict HTTP on port 80 and RDP on port 3389 to the competition subnet only. The application connects to the Management Backend internally via 192.168.1.30:5000.

User Account Hardening Unnecessary local user accounts were audited and removed from the machine. The default Administrator password was changed to the TSI value provided via IScorE. Only IT Administrators (melissa.robles, roger.cox) retain local administrator privileges on this machine.

WWW Public Website

Server: www.team6.isucdc.com
IP (external): 79.5.64.50
IP (internal): 192.168.1.50
Operating System: AlmaLinux 9

The Public Website is the citizen-facing portal for the transit system. Citizens can register, log in, view bus and train routes, buy tickets, and scan tickets from this site. It is a Flask-based Python application located at /home/cdc/icdc2026frontend-main, running as a systemd service called "frontend" on port 80. It communicates with the Management Backend at 192.168.1.30:5000 for all authentication, payment, and ticketing operations.

A full code audit was performed on the application and 20 vulnerabilities were identified ranging from critical to medium severity. The following were remediated.

Session Security — Secret Key The hardcoded SECRET_KEY of "cdc" was replaced with a cryptographically secure 64-character random hex string generated using Python's secrets module. The original weak key allowed any attacker to forge valid session cookies and impersonate any user including administrators, completely bypassing authentication.

Session Security — Cookie Protections SESSION_COOKIE_HTTPONLY was enabled to prevent JavaScript from reading session cookies, blocking XSS-based session theft. SESSION_COOKIE_SAMESITE was set to "Lax" to add CSRF protection by preventing cookies from being sent on cross-site requests.

Authentication Enforcement A login_required decorator was created and applied to all sensitive routes including /profile, /get_tickets, /buy_ticket, /activate_ticket, /delete_ticket, /scan_ticket, /get_ticket, /get_payment_info, and /update_payment_info. Prior to this fix, every one of these endpoints was fully accessible without any authentication.

XSS Fixes in Templates Two XSS vulnerabilities in profile.html and scan.html were fixed. Both templates were injecting a URL message parameter directly into a JavaScript variable without escaping, allowing script injection. The fix applied Flask's tojson filter and html.escape() to properly sanitize output before rendering. User-supplied input passed to templates was also escaped using Python's html module.

Input Validation Server-side input validation was added for ticket IDs and usernames. Ticket IDs are now validated against a strict alphanumeric pattern, blocking path traversal attempts. Usernames are validated against a safe character pattern before being processed, preventing injection through login fields.

Security Headers HTTP security headers were implemented including X-Content-Type-Options, X-Frame-Options, and X-XSS-Protection to add browser-level protections against common attack vectors.

Firewall Configuration firewalld was configured to allow only SSH on port 22 and HTTP on port 80. All other inbound traffic is blocked.

Default Account Hardening The default cdc user password was changed to the TSI value provided via IScorE. SSH access was restricted to the IT Administrator accounts only via the AllowUsers directive in sshd_config, preventing any other account from authenticating remotely. File permissions on /etc/passwd, /etc/shadow, and /etc/ssh were audited and corrected to prevent unauthorized modification.

Netcat Backdoor Listeners A malicious bash script was found running as a background process, spawning three persistent netcat listeners on ports 12345, 12069, and 1337, each piping input directly to bash for unauthenticated remote code execution. All three netcat processes were killed and the source script was located and deleted.

Malicious Shared Library (LD_PRELOAD Rootkit) A malicious shared library was found loaded via the LD_PRELOAD environment variable at /usr/lib64/nsabackdoor.so. By hooking system calls at the library level, it caused standard tools like ls, ps, netstat, and ss to report falsified output, hiding files, processes, and network connections from defenders. The source code at /usr/src/debug/nsabackdoor.c confirmed it was a custom-built implant. Both the library and source code were deleted and LD_PRELOAD was confirmed empty post-removal.

Login Persistence via /etc/profile.d The rootkit persisted via /etc/profile.d/setup.sh, a script that executed automatically on every user login and re-set LD_PRELOAD to reload the malicious library. Deleting this script fully removed the persistence mechanism.

Sudoers Backdoor A line reading ALL ALL=(ALL) NOPASSWD: ALL was found in /etc/sudoers, granting every user on the system full passwordless root access. This was removed using visudo and replaced with properly scoped sudo rules requiring password authentication.

Post-Remediation Verification Process listings, network connections, and LD_PRELOAD were all re-verified with clean output after removal. File permissions across /etc/passwd, /etc/shadow, /etc/ssh, and the Flask application directory were audited and corrected.

Known Remaining Risks Three vulnerabilities were identified but not fully remediated due to time constraints. XSS via innerHTML manipulation in tickets.js and map.js remains partially unaddressed. CSRF token protection on forms was not fully implemented as it required coordinated changes across every template and AJAX call. Several state-changing operations such as ticket activation and deletion still use GET requests rather than POST. These are lower priority given that SameSite cookie protection provides partial CSRF mitigation, but they remain attack surface during the active phase.

User Roles and Access Controls

User Roles & Access Control
All user accounts are managed through Active Directory and authenticated via LDAP/LDAPS from the domain controller at 192.168.1.10. Passwords for IT Administrators and privileged roles are set to the Team-Specific Information (TSI) values provided via IScorE. The four user roles and their access rights are detailed below.

IT Administrators
— **melissa.robles**
— **roger.cox**
IT Administrators have the highest level of access across the entire infrastructure. On all three Windows servers (Active Directory, Ticketing Machine, Admin UI), they are members of the local Administrators group and are permitted to RDP on port 3389. On both Linux servers (Management Backend, Public Website), they have SSH access on port 22 with full sudo privileges. They are the only role with administrative access to all five machines.

Transit Admins
— **edward.matthews**
— **joy.newman**
Transit Admins have access exclusively to the Admin UI web interface on port 80. They can log in, view the status of the city's transportation fleet, and manage vehicles including triggering the service disruption flag functionality. They do not have RDP or SSH access to any server.

Ticket Maintenance
— **andrea.hall**
— **geoffrey.mitchell**
Ticket Maintenance staff have RDP access to the Ticketing Machine only on port 3389 with Administrator-level privileges on that machine. This is required for managing and maintaining the ticketing application. They do not have access to any other server.

Citizens
— **joann.wilson**
— **leslie.brady**
— **michael.miranda**
— **krystal.gray**
Citizens have access to the Public Website only via HTTP on port 80. They can register, log in, view routes, purchase tickets, and scan tickets. They have no administrative access to any system.

Known Risk and Monitoring

Known Risks & Monitoring

This section documents vulnerabilities that were identified but not fully remediated prior to the competition's attack phase, as well as monitoring measures put in place across the infrastructure.

Remaining Application Vulnerabilities — Public Website

Three vulnerabilities in the public website Flask application remain partially unaddressed. These represent the primary application-layer attack surface during the active phase.

- XSS via innerHTML manipulation exists in tickets.js and map.js, where unsanitized data is inserted directly into the DOM.
- CSRF token protection was not fully implemented across all forms and AJAX calls, though the SameSite=Lax cookie policy provides partial mitigation.
- Several state-changing operations including ticket activation and deletion still use GET requests rather than POST, meaning they can be triggered via URL alone.

Management Backend — SQL Injection Review A code-level SQL injection audit of the management backend was initiated. The application uses SQLAlchemy ORM for the majority of database operations, which provides parameterized query protection by default. Raw SQL usage was not confirmed in the reviewed routes, though a complete line-by-line audit of payment.py and tickets.py was not fully completed before the attack phase. The "Database Access" flag for the blue_flag payment record represents a potential attack vector if any raw query interpolation exists in payment lookup routes.

Monitoring — Linux Servers

auditd is enabled on both AlmaLinux servers for system call auditing and tracking file access, privilege escalation attempts, and user activity. System logs at /var/log/secure and /var/log/messages are monitored for failed SSH attempts and authentication anomalies. journalctl is used to monitor the frontend and backend systemd services in real time.

Monitoring — Windows Servers

Sysmon is deployed on all three Windows servers with a configuration tuned to log process creation, network connections, file creation, and registry modifications. Windows Event Viewer is used to monitor authentication events, RDP login attempts, and account management activity across Active Directory, the Ticketing Machine, and the Admin UI.

General Posture

All default passwords for cdc and Administrator have been changed. Firewall rules are in place on all five servers restricting traffic to only required ports and sources. The most critical known pre-planted threat, the rootkit on the public website, has been fully remediated. The team will monitor service availability throughout the attack phase and prioritize restoring any scored services that go down.